SEMANA 10 · UNIDAD 2 · SEGURIDAD EN REDES

Hardening y gestión de vulnerabilidades: parcheo, CVEs, escaneo de vulnerabilidades

Ing. Rodolfo Cañas Cervantes
Universidad de la Costa (CUC) · Ingeniería de Sistemas
Semana 10 · Periodo 2026-2 · Barranquilla, Colombia

PARTE 1 DE 4 · EL CICLO DE GESTIÓN DE VULNERABILIDADES

CVE y CWE | CVSS v4.0 | EPSS | CISA KEV

MAPA

De dónde venimos y qué veremos esta semana

Cuatro bloques: el ciclo y sus señales, el escaneo, la remediación y la práctica en el laboratorio.

SEMANA 10 · Hardening y gestión de vulnerabilidades

De la red que cuenta lo que pasa a la red que muestra lo que tiene abierto

Parte 1 · Ciclo y señales

CVE · CVSS v4.0 · EPSS · KEV
las tres señales de prioridad

salida: decisión informada

Parte 2 · Descubrimiento

inventario · nmap y sus estados
escaneo autenticado · Greenbone

salida: un reporte de hallazgos

Parte 3 · Priorizar y parchear

árbol de decisión · parcheo
mitigaciones · hardening CIS

salida: remediación verificada

Parte 4 · Caso y práctica

Keralty 2022 · marco CO
nmap + Greenbone en el Lab 1

salida: el ciclo cerrado en el lab

Hilo conductor de la semana

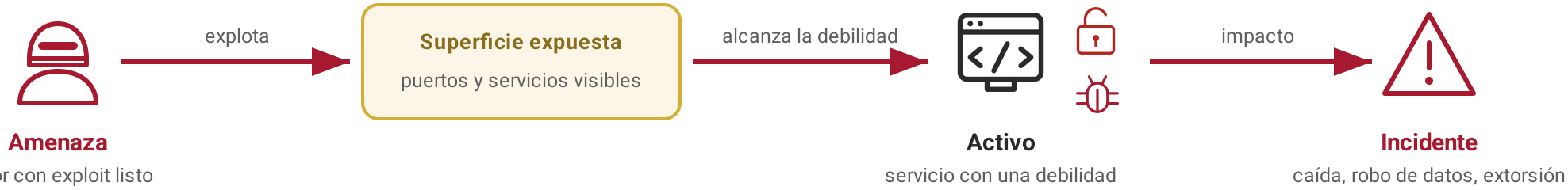
Todo termina en la misma topología del laboratorio: nmap descubre los servicios de la DMZ,
Greenbone los compara con su base de conocimiento y el ciclo termina cuando el re-escaneo sale limpio.

Diagrama propio · plan de la semana: docs/analisis-tematico.md §2.4

POR QUÉ

Una debilidad expuesta es una puerta abierta

Cuatro palabras que sostienen toda la semana: activo, vulnerabilidad, amenaza y riesgo.



Activo
equipo, servicio o dato que vale la pena proteger

Vulnerabilidad
debilidad de software o de configuración

Amenaza
quien puede abusar de esa debilidad, con exploit

Riesgo
severidad × probabilidad × exposición del activo

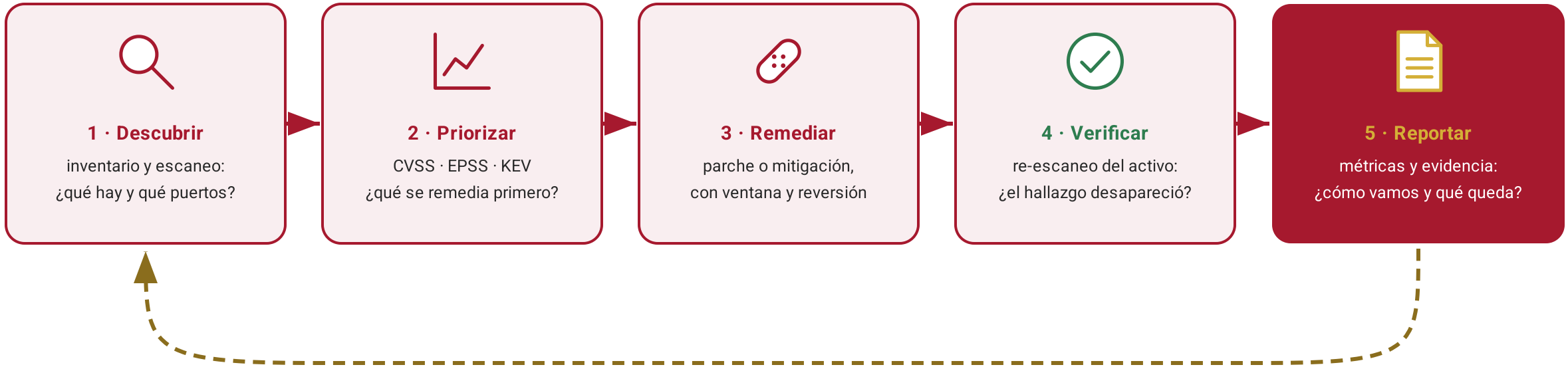
La pregunta de la semana no es «¿tenemos vulnerabilidades?»: es «¿cuáles están expuestas y hasta cuándo?»

Diagrama propio · vocabulario: ISO/IEC 27000:2018 · NIST CSF 2.0 (2024)

CICLO

El ciclo de gestión: cinco pasos que nunca se detienen

Descubrir, priorizar, remediar, verificar y reportar; la vuelta siguiente empieza sola.



No es un proyecto, es un proceso

Un escaneo aislado envejece en semanas. La norma pide calendario, responsables y evidencia de cada vuelta: la regla de esta semana es que un hallazgo solo cierra cuando el re-escaneo lo demuestra.

NIST SP 800-40 Rev.4 (2022) · ISO/IEC 27002:2022, control 8.8 · CIS Controls v8.1 (2024), Control 7

Cómo se nombra una debilidad: CWE, CVE y NVD

Un vocabulario común hace que el hallazgo de mi escáner sea el mismo que el de su boletín.

CWE · el tipo
catálogo de patrones de debilidad (comunidad MITRE)

→

CVE · el caso
identificador único CVE-AAAA-NNNNN, con año

→

NVD · el contexto
enriquecimiento del NIST: severidad, CPE, referencias

→

Su escáner
compara el CPE instalado contra esta base pública

EJEMPLO REAL: LOG4SHELL, DICIEMBRE DE 2021 (RESUMIDO)

Tipo: CWE-502, deserialización de datos sin confianza

caso: CVE-2021-44228, en la biblioteca de registros Log4j 2

casi todo el ecosistema Java heredó la debilidad

contexto NVD: severidad máxima y CPE de las

versiones afectadas, de 2.0-beta9 hasta 2.15.0

con eso, cualquier escáner sabe si su equipo la tiene

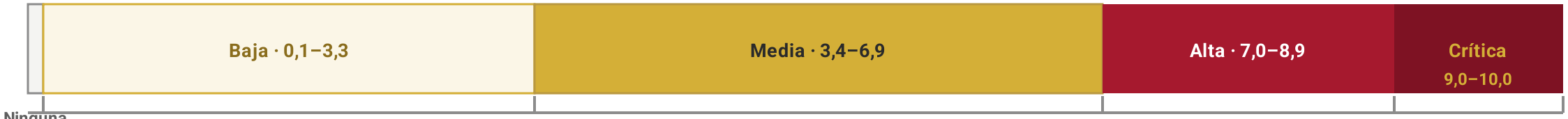
El identificador CVE es el código de barras de la debilidad:
con él se conectan escáneres, boletines, prioridades y métricas; sin él, cada herramienta hablaría un idioma distinto.

SEVERIDAD

CVSS v4.0 mide el golpe, no la probabilidad

Un número de 0 a 10 para la severidad del peor escenario razonable; nada más.

ESCALA DE SEVERIDAD (0,0 A 10,0) · UMBRALES OFICIALES DE LA VERSIÓN 4.0



El número describe la severidad del caso en el peor escenario razonable: no dice si alguien lo está usando hoy.

Lo que sí mide

· la severidad intrínseca: cuánto duele el caso

· cómo llega: por red, adyacente, local o físico

· qué privilegios y preparación exige el atacante

· el daño sobre el activo y sobre el que sigue detrás

Lo que NO mide

· si la vulnerabilidad ya se está explotando

· cuánto le importa a mi negocio ese activo

· si mi servicio está o no expuesto a Internet

para eso existen EPSS, KEV y las señales de la parte 3

La versión 4.0 la publicó FIRST en noviembre de 2023, sucesora de la 3.1 de 2019.

Agregó impactos separados para el sistema vulnerable y el subsiguiente, y métricas complementarias. El curso la usa por defecto.

FIRST, CVSS v4.0 Specification (2023), §8: escala cualitativa

Por dentro del vector: cada letra es una decisión

La base suma explotabilidad e impactos; amenaza y entorno agregan el contexto.

EL VECTOR ES UNA CADENA DE DECISIONES ENCADENADAS

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H`

Explotabilidad · ¿qué tan fácil llega?

AV	AC	AT	PR	UI
vector de acceso	complejidad del ataque	requisitos previos	privilegios necesarios	interacción del usuario

la fila de arriba del ejemplo: red, baja, sin requisitos, sin privilegios, sin interacción: llega sola y de afuera

Impactos · ¿cuánto daño?

VC · VI · VA	SC · SI · SA
sobre el activo vulnerable	sobre el sistema que sigue detrás

C confidencialidad · I integridad · A disponibilidad, valoradas de nula a alta; el ejemplo las lleva todas altas

Los grupos suman contexto

solo base: CVSS-B · con amenaza: CVSS-BT

con entorno del activo: CVSS-BTE

Regla para los reportes del curso

el número resume, el vector explica:

cítense siempre los dos, sin excepción

VOLUMEN

Nadie alcanza a parchear todo: la aritmética manda

Del catálogo completo al fragmento que de verdad produce incidentes.

401 104 CVE acumuladas en la NVD

catálogo completo a octubre de 2026; se suman decenas de miles cada año

miles quedan con severidad alta o crítica

pero severidad alta no significa que se esté explotando

1 734 en el catálogo KEV

con evidencia de explotación real (oct-2026)

La lectura

· menos del 0,5 % del catálogo total está en la lista de explotadas,

· pero ese fragmento concentra los incidentes que leen los periódicos,

· por eso recibe los plazos cortos y la primera atención del defensor.

Regla práctica de esta semana:
KEV primero, EPSS después, CVSS ordena el resto

La conclusión operativa

Ningún equipo de operación alcanza a mirar cuatrocientas mil entradas, y menos a probar cada parche.
Priorizar no es un lujo metodológico: es la única estrategia posible. Las dos señales siguientes hacen ese trabajo.

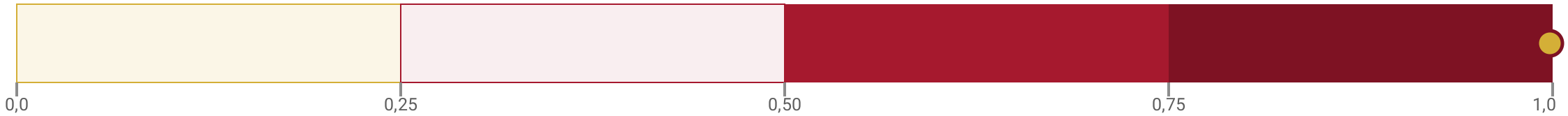
NVD API: 401 104 CVE acumuladas (consultado 4-oct-2026) · CISA KEV: 1 734 entradas (consultado 4-oct-2026)

PROBABILIDAD

EPSS: la probabilidad de que alguien la explote

La segunda señal estima, con datos reales, si una vulnerabilidad se usará en los próximos 30 días.

LA ESCALA DE EPSS VA DE 0 A 1 (0 % A 100 %) Y SE PUBLICA CON SU PERCENTIL



Log4Shell: EPSS 0,99999 · percentil 1,0 (consultado 4-oct-2026)

Qué pregunta

¿aparecerá en intentos de explotación en 30 días?

Con qué datos

observación de explotación real, no opiniones ni rumores

Cuándo cambia

se recalcula todos los días; el CVSS, en cambio, es fijo

Cómo se lee: 0,9 no es «90 % de daño», es 90 % de probabilidad de ver explotación en 30 días.

CVSS dice cuánto puede doler; EPSS dice qué tan probable es que duelan hoy. Juntas valen más que cualquier número solo.

FIRST, Exploit Prediction Scoring System (epss.first.org) · CVE-2021-44228: 0,99999, percentil 1,0 (consultado 4-oct-2026)

EVIDENCIA

El catálogo federal de lo que ya se está explotando

Tercera señal: la lista pública de vulnerabilidades con evidencia de explotación en la naturaleza.

nov 2021 — 1 — nace el catálogo con la directiva federal 22-01

2022–2025 — 2 — crece con cada aviso de explotación real

jun 2026 — 3 — la directiva 26-04 ordena priorizar parches por riesgo

oct 2026 — 4 — 1 734 entradas vigentes (consultado hoy)

ANATOMÍA DE UNA ENTRADA REAL DEL CATÁLOGO (CONSULTADA HOY)

Identificador	Producto afectado	Fecha de alta	Fecha límite	Triaje forense
CVE-2026-88779	**Citrix NetScaler**	**2026-10-04**	**2026-10-07**	**requerido**
el código que conecta con su escáner	con su CWE asociado, la debilidad tipo	cuando quedó demostrada la explotación	tres días para las agencias federales	¿el activo ya está comprometido?

Regla del curso

Si una vulnerabilidad está en el catálogo, la discusión se acaba: va al frente de la fila, con plazo corto y revisión del activo.

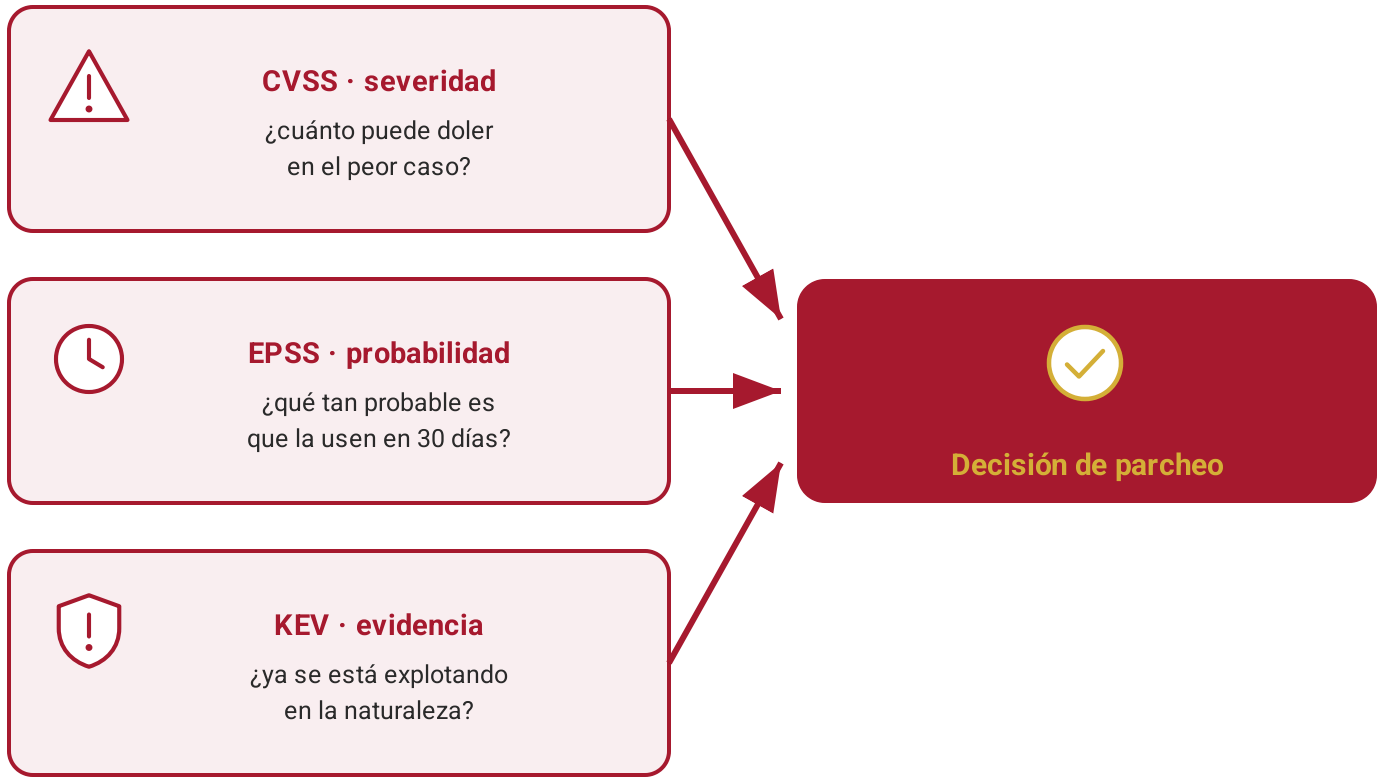
Los tres días de la directiva aplican a agencias federales de Estados Unidos; su organización fija los suyos, pero cortos.

CISA, Known Exploited Vulnerabilities Catalog (cisa.gov): 1 734 entradas, consultado 4-oct-2026 · BOD 22-01 (2021) · BOD 26-04 (2026)

DECISIÓN

Tres señales, una sola decisión informada

La severidad ordena, la probabilidad avisa y la explotación confirmada decide.



Alta + alta + en catálogo → hoy mismo

remediación inmediata y revisión forense del activo

es exactamente el caso de Log4Shell, que viene ahora

Alta severidad + probabilidad baja → ventana

parcheo programado del ciclo regular, sin pánico

la mayoría de los hallazgos críticos vive aquí

Baja severidad + probabilidad alta → vigilar

endurecer el activo y monitorear, sin esperar el turno

aquí el hardening de la parte 3 gana la partida

Baja + baja + fuera del catálogo → lista de deuda

se remedia en el mantenimiento planificado

documentada, nunca olvidada

Diagrama propio · método: FIRST (CVSS v4.0, EPSS) + CISA (KEV, BOD 26-04)

CASO GLOBAL

Log4Shell: las tres señales disparadas a la vez

Una biblioteca de registros casi invisible puso de pie al ecosistema Java en diciembre de 2021.

9 dic 2021 — 1 — se divulga la falla en la biblioteca Log4j 2 de Java

10 dic 2021 — 2 — CVE-2021-44228: CVSS 10,0; KEV el mismo día, plazo 24 dic

días después — 3 — exploit público y en masa: de 2.0-beta9 hasta 2.15.0 (NVD)

hoy, oct 2026 — 4 — EPSS 0,99999, percentil 1,0: sigue siendo explotada a diario

CVSS: 10,0 sobre 10

severidad máxima por el NVD: llega por red y toma el control

EPSS: 0,99999

percentil máximo, aún hoy: casi segura en cualquier mes

KEV: desde el día uno

agregada el 10-dic-2021 con plazo de 14 días: 24-dic-2021

La lección para este curso

Una biblioteca de registros, que casi nadie lista en su inventario, expuso a medio mundo Java. Nadie la parchea si el escáner no la ve dentro del producto; por eso esta semana insistimos en inventario, escaneo autenticado y versiones exactas.

NVD CVE-2021-44228 (2021): CVSS v3.1 10,0 · KEV: alta 10-dic-2021, límite 24-dic-2021 · EPSS 0,99999 (4-oct-2026)

De la señal al plazo: una política que se pueda cumplir

Las señales se convierten en relojes: el ejemplo federal y una política local razonable.

EL EJEMPLO FEDERAL (DIRECTIVA 26-04) PREGUNTA CUATRO COSAS ANTES DE FIJAR EL RELOJ

1 · ¿El activo está expuesto a Internet?
un servidor publicado corre más riesgo que uno interno

2 · ¿La vulnerabilidad está en el catálogo KEV?
evidencia de explotación, no teoría ni boletín

3 · ¿El adversario puede automatizar el exploit?
un exploit repetible escala a miles de equipos por hora

4 · ¿El impacto técnico da control total?
ejecutar código a voluntad pesa más que denegar servicio

El caso más apretado de la directiva

En el catálogo KEV con triaje forense:

tres días para remediar y revisar el activo

aplica a agencias federales desde jun-2026; la idea viaja: reloj corto y revisión de compromiso

EJEMPLO DE POLÍTICA LOCAL (ILUSTRATIVA)

Crítica y expuesta	máx. 7 días
Alta	máx. 30 días
Media	máx. 90 días
Baja o sin exposición	ventana siguiente

Los plazos de la derecha son un ejemplo de política, no una norma: cada organización los calibra con su apetito de riesgo. Lo innegociable: en KEV, reloj aparte y corto.

MÉTRICAS

El programa se mide: cobertura, reloj y deuda

Un tablero sencillo responde la única pregunta de la gerencia: ¿el riesgo abierto baja o sube?

TABLERO DE EJEMPLO CON VALORES ILUSTRATIVOS: LO QUE IMPORTA ES LA TENDENCIA, NO EL NÚMERO

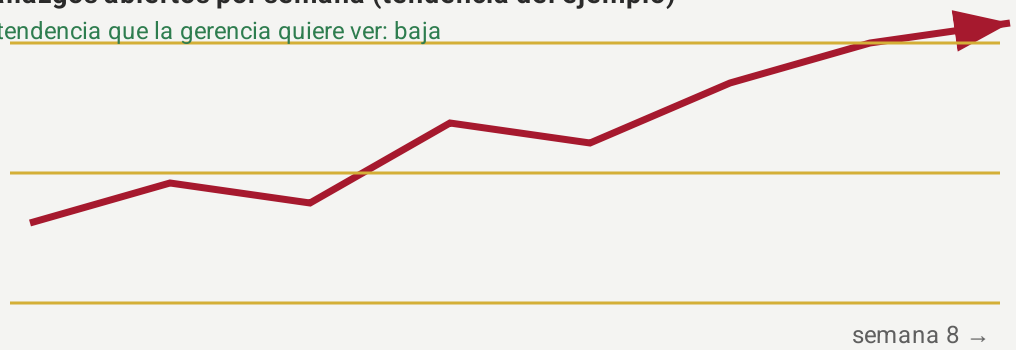
92 %
cobertura de escaneo
activos vistos / inventario

21 días
remediación media, críticas
contra el plazo de la política

47
hallazgos abiertos
la deuda, ordenada por prioridad

100 %
hallazgos KEV en plazo
el indicador que no se negocia

Hallazgos abiertos por semana (tendencia del ejemplo)
la tendencia que la gerencia quiere ver: baja



si sube dos semanas seguidas, hay que explicarlo con acción, no con adjetivos

Cómo se reporta en la práctica

· a operación: la lista de la semana, por activo y responsable

· a gerencia: cobertura, reloj y tendencia, una sola página

· a auditoría: evidencia de cada cierre, con re-escaneo

· cada número con su fecha de corte y su fuente

Pregunta del día: ¿estamos midiendo el programa o solo contando escaneos?

Diagrama propio · métricas de programa: NIST SP 800-40 Rev.4 (2022) · valores del tablero: ilustrativos

SÍNTESIS

Lo que queda de la Parte 1

El vocabulario, el idioma común, las tres señales y el reloj: la base para decidir.

1 · El ciclo no termina

descubrir, priorizar, remediar, verificar y reportar;
cada re-escaneo programado empieza la vuelta siguiente.

tratarlo como proyecto de una sola vez es el error clásico

2 · Un idioma común

la debilidad tipo, el caso con identificador único
y el contexto de la base nacional de vulnerabilidades.

con un solo código, escáner y boletín hablan lo mismo

3 · Tres señales, no un número

severidad, probabilidad a 30 días y evidencia de explotación;
el catálogo KEV salta la fila completo.

log4shell lo demostró: las tres disparadas a la vez

4 · Señal sin reloj es opiniación

la política convierte las señales en plazos con responsable;
exposición, catálogo, automatización e impacto.

las cuatro preguntas del ejemplo federal de junio de 2026

Ahora baja la parte teórica al terreno: ¿qué equipos y servicios hay, y qué responden?

En la Parte 2 los descubrimos con nmap y los interrogamos con Greenbone, sobre el laboratorio del curso.

Diagrama propio · síntesis de la Parte 1

PARTE 2 DE 4

2

Descubrimiento y escaneo

Semana 10 · Hardening y gestión de vulnerabilidades: parcheo, CVEs, escaneo de vulnerabilidades

nmap | Estados de puertos | Escaneo autenticado | Greenbone/OpenVAS

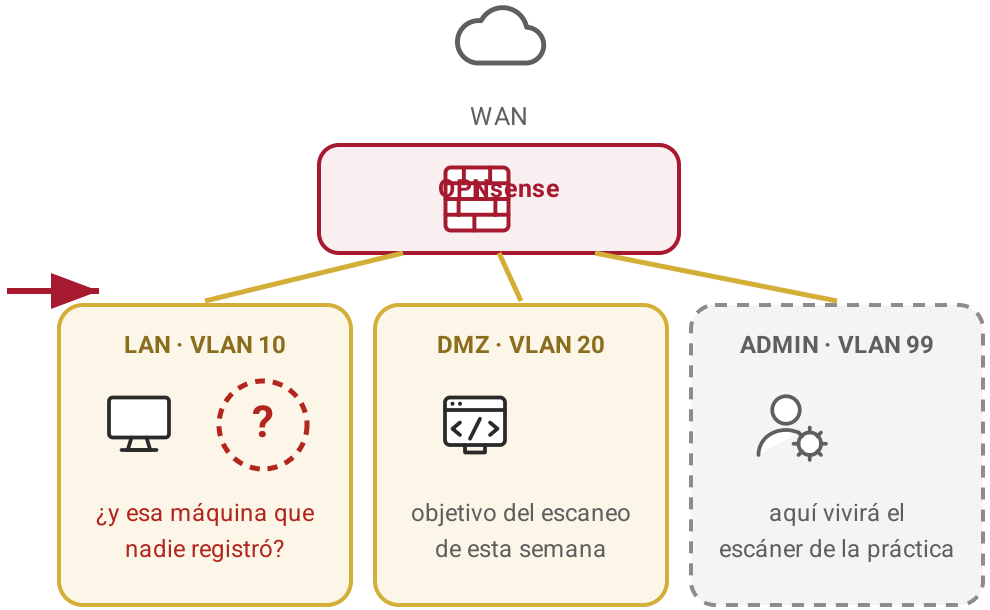
No se protege lo que no aparece en el inventario

Las señales de la Parte 1 necesitan un mapa: quién está en la red y qué hace.

Lo que ya tienen

- el ciclo de cinco pasos y sus tres señales
- una política con relojes para cada severidad
- lo que falta: saber a qué aplicar todo eso

la teoría opera sobre activos reales



Por qué envejece el inventario

- direcciones dinámicas cambian de dueño cada día
- máquinas de prueba que nadie apaga y nadie lista
- equipos de oficina, cámaras y dispositivos conectados
- servicios que vuelven a casa de terceros y contratistas

El inventario se descubre, no se declara.

La regla que abre la Parte 2

El control uno de la práctica del centro de seguridad de internet es conocer el inventario; el control siete es gestionar sus vulnerabilidades. Van siempre juntos: el escaneo de descubrimiento es la manera de mantener el mapa al día.

Diagrama propio · concepto: CIS Controls v8.1 (2024), Controles 1 y 7 · topología: Lab 1 del curso

Primer sondeo: quién responde en la red

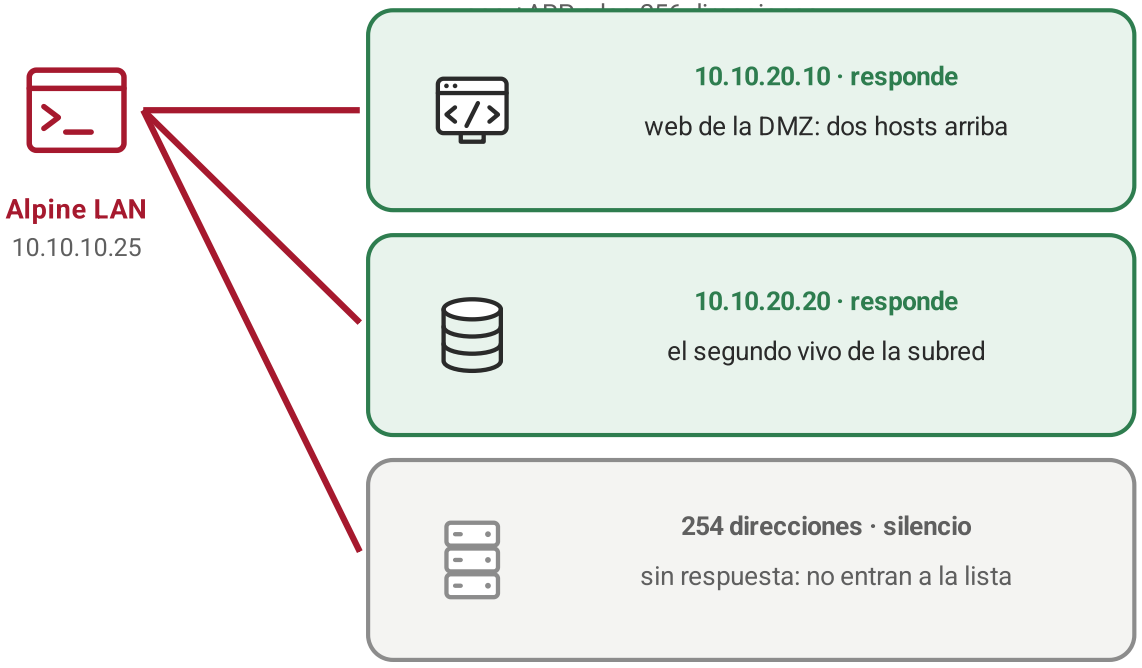
Con el sondeo de descubrimiento se arma la lista de vivos antes de tocar un solo puerto.

```
# en una Alpine de la LAN, como root
apk add nmap

# solo descubrimiento: sin puertos
nmap -sn 10.10.20.0/24

Starting Nmap 7.99
Nmap scan report for 10.10.20.10
Host is up (0.0012s latency).
MAC: 08:00:27:xx:xx:xx (VirtualBox)
Nmap scan report for 10.10.20.20
Host is up (0.0008s latency).
Nmap done: 256 addresses (2 hosts up)
scanned in 1.81 seconds
```

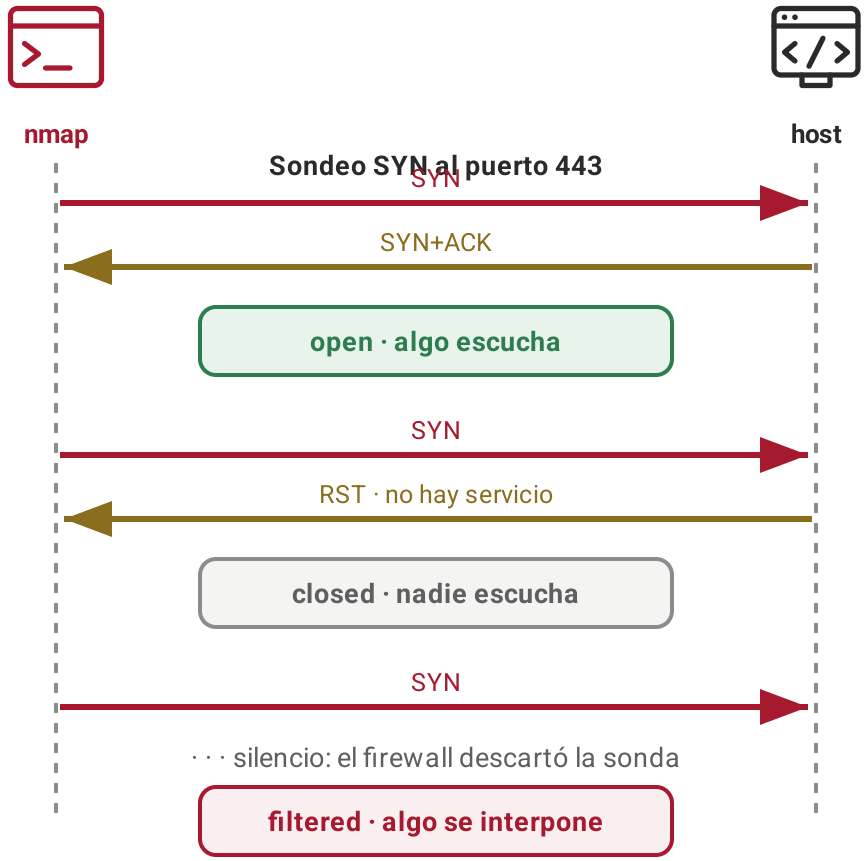
Si el firewall bloquea el eco: `nmap -Pn` asume que el host vive y pasa a escanear puertos. Con `-sn`, quien no contesta no aparece.



-sn = «sin escaneo de puertos»:
solo contesta quién está vivo; el interrogatorio viene después

Las seis respuestas que puede dar un puerto

Misma sonda, tres finales distintos; de ahí salen los estados que nmap reporta.



LOS SEIS ESTADOS QUE REPORTA NMAP

open	un servicio escucha y acepta la conexión; la puerta por donde se entra a explotar
closed	nadie escucha, pero el host responde: alcanzable; un arranque podría abrirlo
filtered	un filtro se traga la sonda: nmap no puede decidir: típico detrás del firewall del lab
unfiltered	el host contesta que el puerto es alcanzable, pero sin decir si hay servicio: sale con -sA
open|filtered	la sonda no recibe respuesta clara: abierto y filtrado quedan en la misma bolsa (UDP)
closed|filtered	caso raro del sondeo indirecto por identificación de IP: se aclara a mano

nmap(1): Port States (nmap.org/book/man.html) · RFC 9293 (2022)

Elegir la sonda: cuatro escaneos que cubren el trabajo

Cada opción manda una pregunta distinta; el arte está en saber qué le conviene preguntar a cada puerto.

-sS · sondeo SYN (semiabierto)

`SYN → SYN+ACK → RST`

completa el saludo a medias y suelta la conexión:
rápido y discretas en los registros de la app;
requiere privilegios de root: es el escaneo por defecto

-sT · conexión completa

`SYN → SYN+ACK → ACK`

usa la llamada del sistema operativo, sin privilegios,
pero cada conexión queda en la bitácora del servicio;
toca usarla cuando no hay root, p. ej. desde Windows

-sU · datagramas UDP

`UDP → puerto inaccesable?`

lento: la mayoría responde con silencio y sale
«open|filtered»; imprescindible para DNS (53),
DHCP (67) y SNMP (161): los servicios de red clásicos

-sA · reconocimiento ACK

`ACK → ¿RST o silencio?`

no sirve para hallar abiertos: sirve para leer el
firewall y saber qué tramos filtran y cuáles no;
ideal para confirmar la frontera del laboratorio

Regla práctica: -sS por defecto con root · -sT sin privilegios · -sU para los servicios de datagramas · -sA para entender al firewall.

Sin la versión exacta no hay CVE que buscar

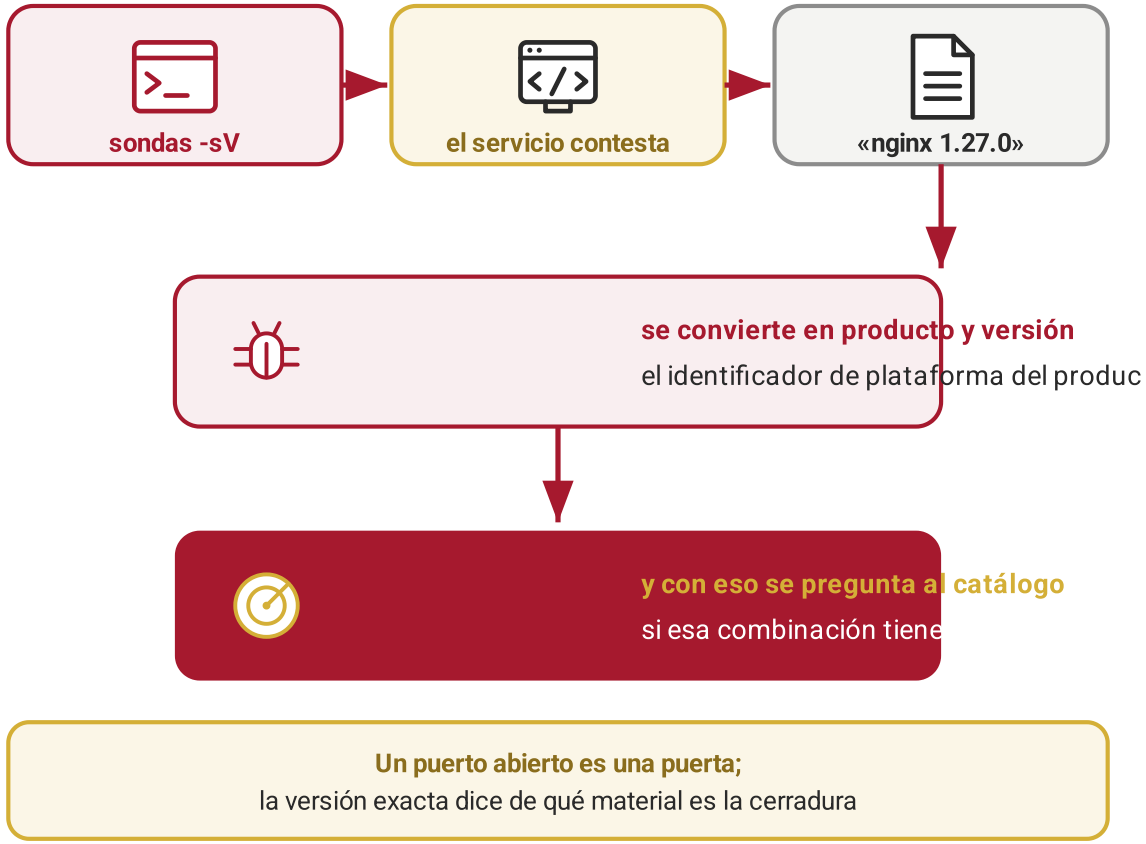
El número de puerto dice poco; la versión del servicio es lo que conecta con el catálogo.

```
# interrogar el servicio, no solo el puerto
nmap -sV 10.10.20.10

PORT    STATE SERVICE VERSION
22/tcp  open  ssh     OpenSSH 9.7
443/tcp open  https   nginx 1.27.0

# ¿de dónde salió? el guion devuelve
# hasta el sistema operativo: -sV -O
```

Lectura: «https» es una suposición por el puerto; «nginx 1.27.0» es un dato del servicio. Con ese dato, el catálogo de la Parte 1 habla.



nmap(1): Service and Version Detection (nmap.org/book/man.html) · salida de ejemplo: ilustrativa

NSE: guiones que prueban la debilidad, no solo nombrarla

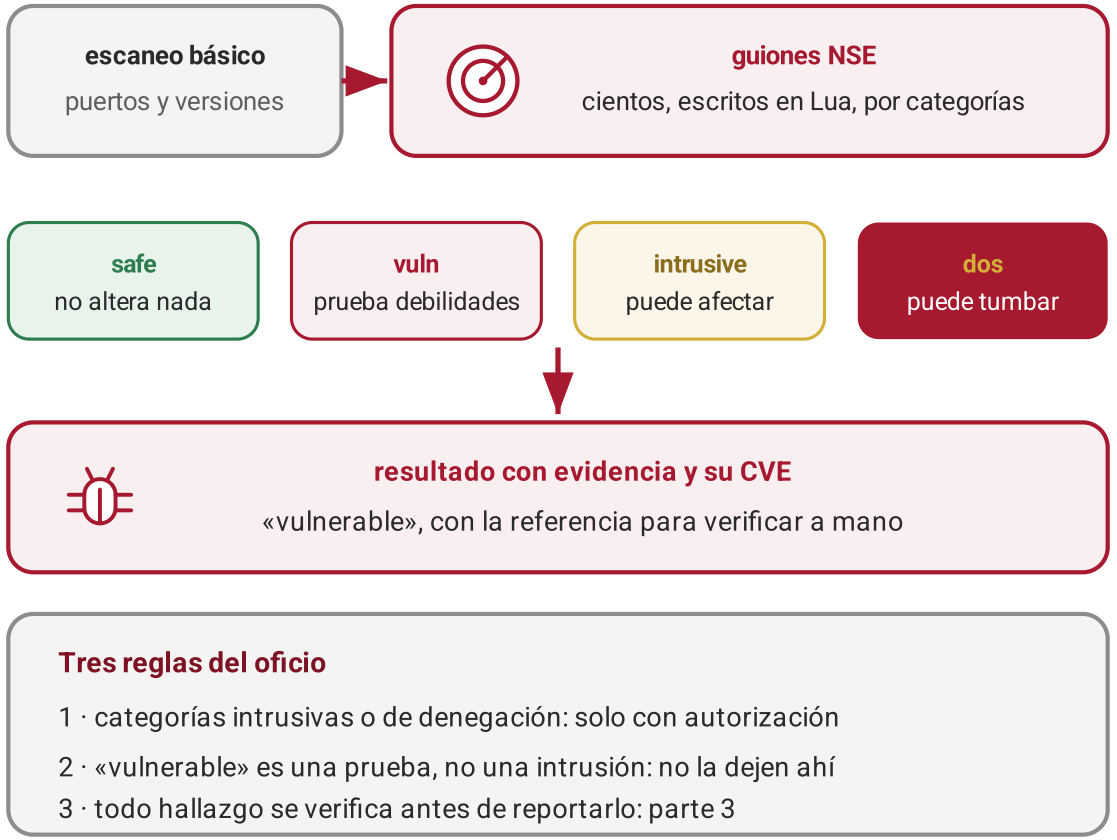
La biblioteca de guiones convierte al escáner en un probador de exploit conocidos.

```
# biblioteca de guiones con categorías
nmap --script vuln 10.10.20.10

# o uno puntual, p. ej. el corazón bleeding
nmap --script ssl-heartbleed 10.10.20.10

443/tcp open  https
| ssl-heartbleed:
|   VULNERABLE: ...
|_S    http://cve.mitre.org/... CVE-2014-0160
```

El guion ya cita el identificador: la salida conecta directo con las señales de la Parte 1. Pero cuidado: `vuln` sondea con *exploits conocidos*, solo en redes propias.



Tres reglas del oficio

1 · categorías intrusivas o de denegación: solo con autorización

2 · «vulnerable» es una prueba, no una intrusión: no la dejen ahí

3 · todo hallazgo se verifica antes de reportarlo: parte 3

REGLAS

Escanear también tiene reglas de enfrentamiento

La misma sonda es una auditoría con autorización o un delito sin ella.

EL MARCO DE PRUEBAS TÉCNICAS DEL NIST (SP 800-115) NO EMPIEZA CON HERRAMIENTAS:

1 · autorización escrita
del dueño del activo, no de un compañero

→

2 · alcance definido
qué redes, ventanas horarias y sondas

→

3 · reglas de enfrentamiento
qué se puede y no se puede tocar

→

4 · evidencia y reporte
todo hallazgo reproducible y documentado

Dentro del perímetro autorizado

· el laboratorio del curso: su red, sus máquinas

· la red de su empresa, con permiso del área de seguridad

· servicios propios en la nube, bajo sus credenciales

· salas de práctica públicas y sus reglas explícitas

en todas: quién autoriza, hasta dónde y con qué evidencia

Fuera del perímetro: la ley 1273 de 2009

· redes de terceros sin autorización escrita

· «solo estaba mirando puertos» no es defensa

· el acceso abusivo a un sistema es delito (art. 195A)

· desde la red de la universidad: además, falta al reglamento

el escaneo masivo también deja rastro y dueño de la red lo ve

Regla del curso, sin excepciones

Los escaneos de esta asignatura corren sobre el laboratorio de VirtualBox de cada quien. Ninguna herramienta de esta semana se apunta a una red ajena.

NIST SP 800-115 (2020): pruebas técnicas · Congreso de Colombia, Ley 1273 de 2009, art. 195A y ss.

Con credenciales y sin ellas: dos vistas del mismo equipo

El atacante solo ve lo de afuera; el administrador puede interrogar al equipo por dentro.

Sin credenciales: la vista del atacante



ve: puertos, banners, versiones adivinadas del exterior
…y nada de lo que vive detrás del firewall o sin publicar

Úsela siempre primero:
es exactamente lo que vería quien los ataca desde afuera

Ventaja: cero riesgo de caída del activo. **Límite:** más falsos positivos: adivina versiones desde el banner.

Con credenciales: la vista del administrador



ve: paquetes exactos, kernel, configuración de servicios,
versiones reales: sin adivinar el banner

Menos falsos positivos, hallazgos de configuración
hasta audita ajustes que ninguna sonda de red alcanza a ver

Ventaja: precisión y profundidad. **Límite:** credenciales dedicadas de solo lectura, custodiadas y rotadas.

En la práctica del viernes van los dos: primero el escaneo de afuera para ver la cara pública de la DMZ, y después el autenticado para leer el detalle exacto de cada paquete instalado.

El identificador de plataforma: el código de cada producto

La versión exacta se convierte en este identificador; con él, el escáner consulta el catálogo.

ANATOMÍA DE UN CPE REAL, EL DE LA BIBLIOTECA LOG4J DEL CASO DE LA PARTE 1

`cpe:2.3:a:apache:log4j:2.14.1`

estándar · aplicación · fabricante · producto · versión

el mismo código en la lista del escáner,
en la base nacional y en el boletín del fabricante

1 · el activo
paquetes instalados
con versión exacta

→

2 · el escáner
convierte cada paquete
en su CPE equivalente

→

3 · la base
cada CVE dice qué CPE
y qué versiones afecta

→

4 · el hallazgo
cruce exacto:
activo con CVE conocida

Por qué exigimos escaneo autenticado en el laboratorio

El escáner no busca palabras: busca pares producto-versión. La versión leída por dentro produce hallazgos defendibles; la adivinada por banner produce conversaciones incómodas y horas perdidas en falsos positivos.

NIST, Common Platform Enumeration 2.3 (csrc.nist.gov) · ejemplo: NVD CVE-2021-44228

Anatomía de un escáner de vulnerabilidades

Cinco etapas en línea; debajo, lo que suele fallar en cada una.



QUÉ SUELE FALLAR EN LA PRÁCTICA

un activo apagado	banner que engaña	feed sin actualizar	evidencia sin revisar	reporte sin dueño
escaneo con la red completa encendida	→ escaneo autenticado	→ sincronizar el feed antes	→ verificar antes de abrir ticket	→ asignar responsable

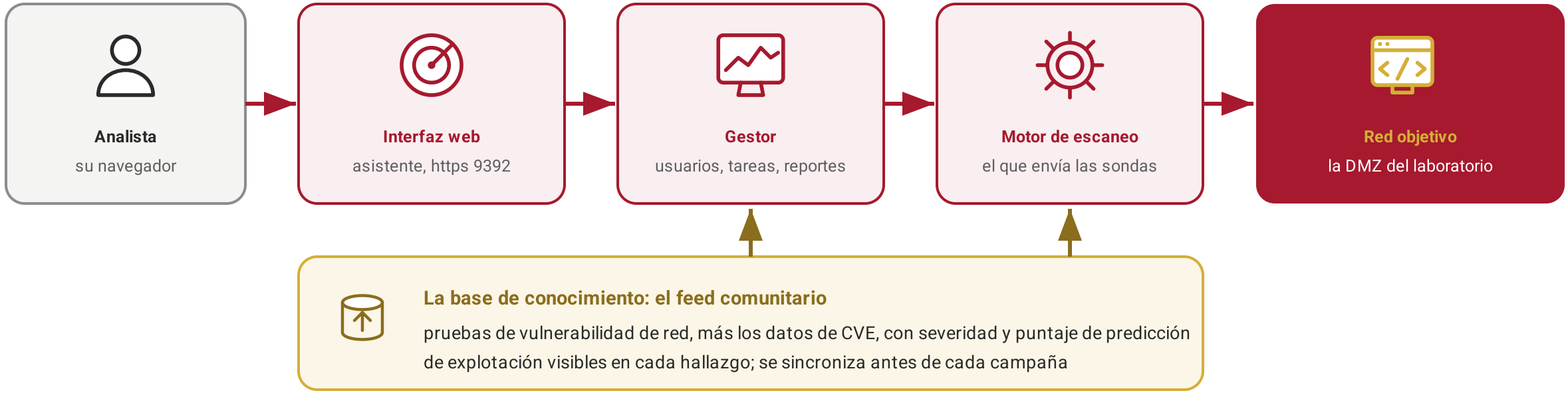
Nota de capacidad

Cada etapa consume tiempo y carga la red: un escaneo completo no es «apretar un botón». Se agenda en ventana, se dimensiona por lotes cuando hay muchos activos, y en la práctica del curso lo veremos con la DMZ completa.

Diagrama propio · concepto: NIST SP 800-40 Rev.4 (2022) · Greenbone docs: flujo de escaneo

El escáner del laboratorio: edición comunitaria de Greenbone

Cuatro piezas en línea y una base de conocimiento que se actualiza sola.



De dónde viene: nació como OpenVAS, bifurcación comunitaria del escáner Nessus en 2005,

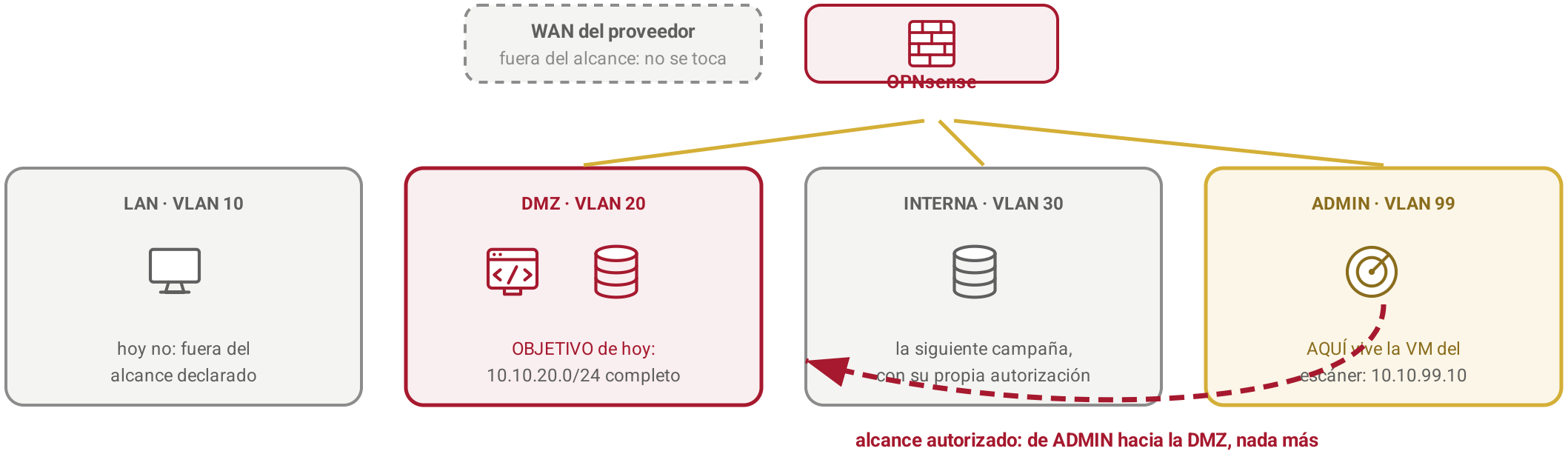
y hoy lo mantiene Greenbone, con licencia abierta; por eso el curso lo usa sin depender de ningún proveedor de nube.

Greenbone: GSA/gsad (github.com/greenbone/gsa): web en 9392 · EPSS activado por defecto · Community Feed (NVT)

PREPARACIÓN

Antes del botón: alcance, credenciales y ventana

Un buen escaneo se decide antes de encenderlo; el laboratorio lo muestra con la DMZ.



Las cuatro decisiones previas

1 · alcance: por escrito, solo la DMZ · 2 · credenciales SSH dedicadas, de solo lectura

3 · ventana: cuando la red esté tranquila · 4 · profundidad: completa y con perfil

más una regla del curso: no se escanea la WAN del proveedor, es red ajena

Por qué la VM del escáner vive en ADMIN

· la zona de administración ya tiene permiso de gestión hacia las demás

· el escaneo autenticado necesita alcance de puerto 22 a los objetivos

· y los reportes quedan dentro del perímetro, nunca en una nube ajena

Diagrama propio · topología de la plataforma del curso: VirtualBox + OPNsense + Alpine (Lab 1)

Leer un hallazgo antes de creerle

Cada línea del reporte trae su propia defensa: evidencia, severidad, host y remedio.

UN RESULTADO DEL REPORTE (EJEMPLO ILUSTRATIVO)

Nombre: versión de servidor con CVE conocida

Identificador CVE: CVE-AAAA-NNNNN

Severidad: 8,6 (alta) · EPSS 0,92 · percentil 0,97

Host y puerto: 10.10.20.10 · 443/tcp

Evidencia: banner y prueba del guion, copiados

Remedio: actualizar el paquete a la versión fijada

Familia: servicio con versión vulnerable

los campos que la interfaz muestra por resultado; el ejemplo es ilustrativo

Cinco preguntas antes de abrir un ticket

1 · ¿el activo importa? criticidad y exposición

2 · ¿la evidencia confirma o solo sugiere?

3 · ¿la versión es la real (autenticado) o adivinada?

4 · ¿qué dicen las señales: EPSS y el catálogo KEV?

5 · ¿el remedio cabe en este activo, en este momento?

Falso positivo: se descarta con evidencia,
y se documenta la prueba y la razón

Falso negativo: el escáner no lo vio;
por eso existen escaneos de credenciales y feed al día

La disciplina del analista

Un hallazgo no es una tarea hasta que alguien lo verifica con las cinco preguntas; ni una emergencia hasta que las señales lo dicen.

SÍNTESIS

Lo que queda de la Parte 2

Descubrir, interrogar y verificar: el mapa de la red convertido en lista de hallazgos.

1 · El inventario se descubre

quién vive en la red, con sondeo programado,
porque el mapa envejece solo.

nmap -sn fue el primer gesto de la práctica

2 · Cada estado significa algo

abierto, cerrado, filtrado: el firewall y el host
responden con silencios que hay que leer.

la versión exacta es la llave del catálogo

3 · Autenticado: precisión

con credenciales dedicadas el escáner lee
versiones reales, no banners adivinados.

menos falsos positivos, hallazgos defendibles

4 · Verificar antes de creer

cinco preguntas, evidencia documentada
y feed sincronizado: el oficio del analista.

Greenbone ordena; el criterio lo pone ustedes

Ya hay una lista de hallazgos verificados: ¿qué se remedia primero?

La Parte 3 convierte el reporte en decisiones: árbol, parche, mitigación y hardening.

Diagrama propio · síntesis de la Parte 2

PARTE 3 DE 4

3

Priorización, parcheo y hardening

Semana 10 · Hardening y gestión de vulnerabilidades: parcheo, CVEs, escaneo de vulnerabilidades

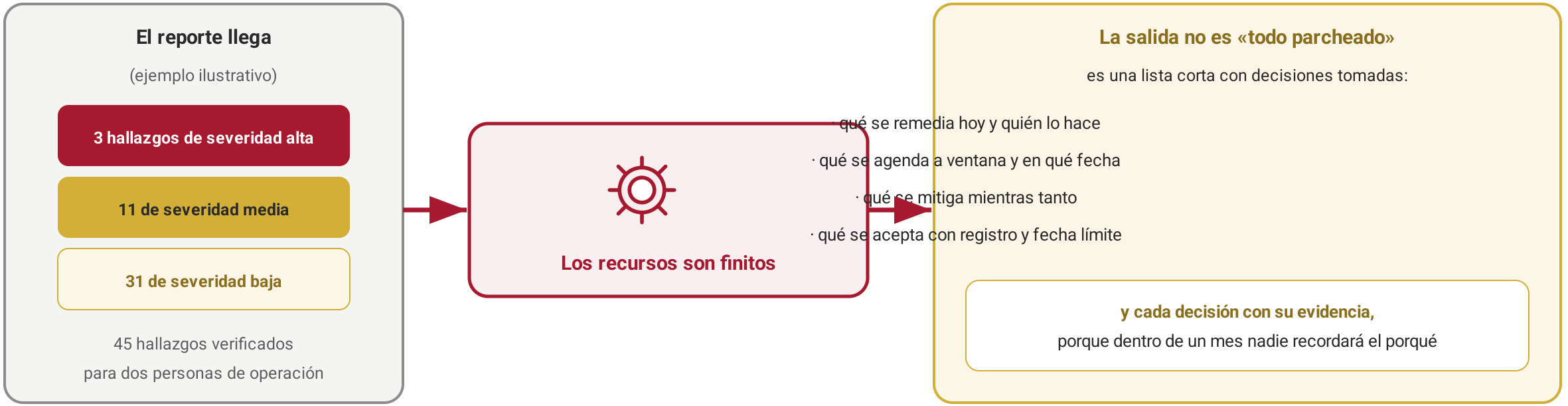
Priorizar | Parcheo | Mitigaciones | CIS

CUC UNIVERSIDAD DE LA COSTA

DECISIÓN

Miles de hallazgos no son un plan: hay que decidir

Priorizar no es ordenar una lista: es decidir qué no se va a hacer hoy.



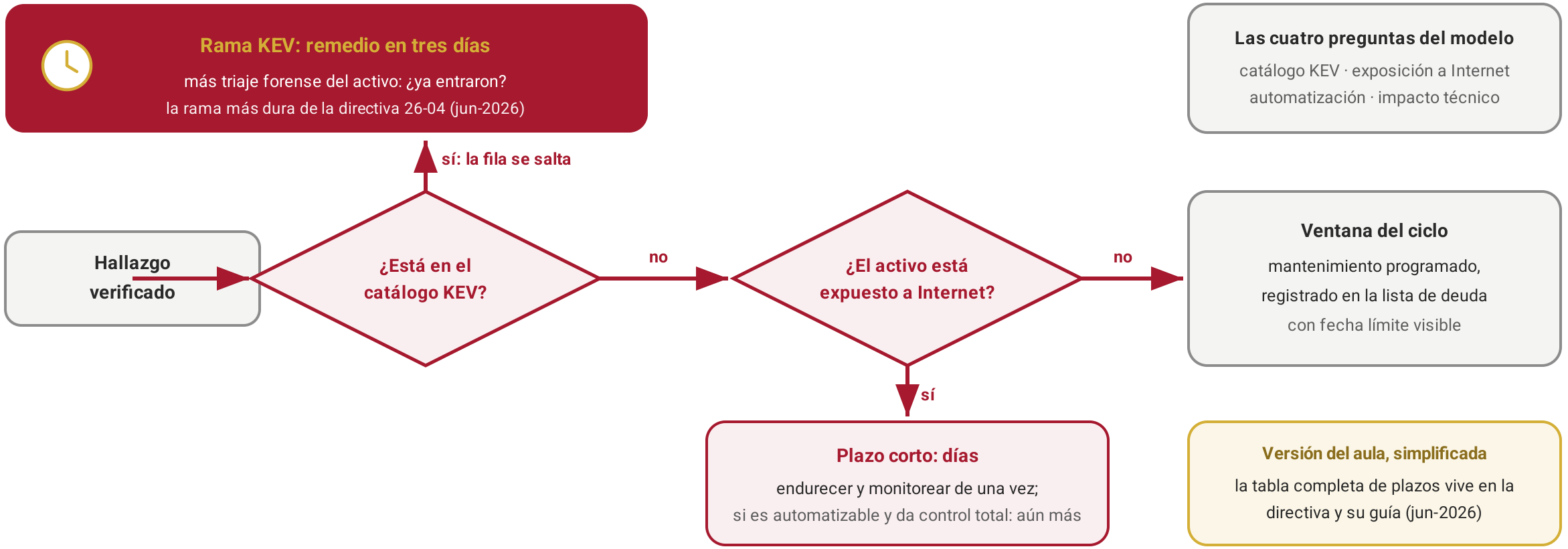
La verdad incómoda de la priorización

Decidir qué va primero obliga a decidir qué va después; y aquello que se queda para «después» tiene que existir en un registro, con plazo, responsable y mitigación. La deuda invisible no es priorización: es abandono con otro nombre.

Diagrama propio · concepto: CISA BOD 26-04 (2026) · NIST SP 800-40 Rev.4 (2022)

El árbol de decisión: cuatro preguntas, una ruta

El método del ejemplo federal de 2026, simplificado para el aula; el catálogo salta la fila.



CONTEXTO

La misma CVE, dos activos, dos prioridades

La severidad pertenece a la vulnerabilidad; la prioridad la pone el activo.

CVE-AAAA-NNNNN · 8,1

CVSS alto, sin distinción



Servidor de la DMZ

publicado en Internet, sostiene el servicio al cliente de la empresa

tratamiento prioritario: días, mitigar ya

aunque la política de tiempo ya lo exige, la exposición lo apura

CVE-AAAA-NNNNN · 8,1

exactamente la misma



Estación de trabajo interna

sin exposición, sin datos críticos, se reinstala en cualquier momento

ventana normal del ciclo de mantenimiento

la misma severidad, otra conversación

El modelo lo formaliza: las métricas ambientales del CVSS ajustan el número al activo,

y la directiva federal pregunta la exposición antes que nada. En el laboratorio el contexto se marca a mano: ¿a qué zona pertenece el host?

FIRST, CVSS v4.0 (2023): métricas ambientales · CISA, BOD 26-04 (2026): exposición del activo

El parche también se gestiona: seis pasos con dueño

La guía del NIST para programas de parches convierte el caos en un proceso auditable.

1 · Monitorear
avisos del fabricante, feed del escáner y catálogo federal

2 · Evaluar
¿tenemos el producto?, ¿qué versión?, ¿está expuesto? (el escaneo)

3 · Adquirir y probar
obtener el parche de fuente oficial y probar en preproducción

4 · Aplicar
en ventana, con respaldo y plan de reversión, de mayor a menor riesgo

5 · Verificar
re-escaneo y revisión de la bitácora: ¿todo funciona como antes?

6 · Registrar
qué, cuándo, quién, resultado y evidencia para la auditoría

Tres papeles, ninguna excusa

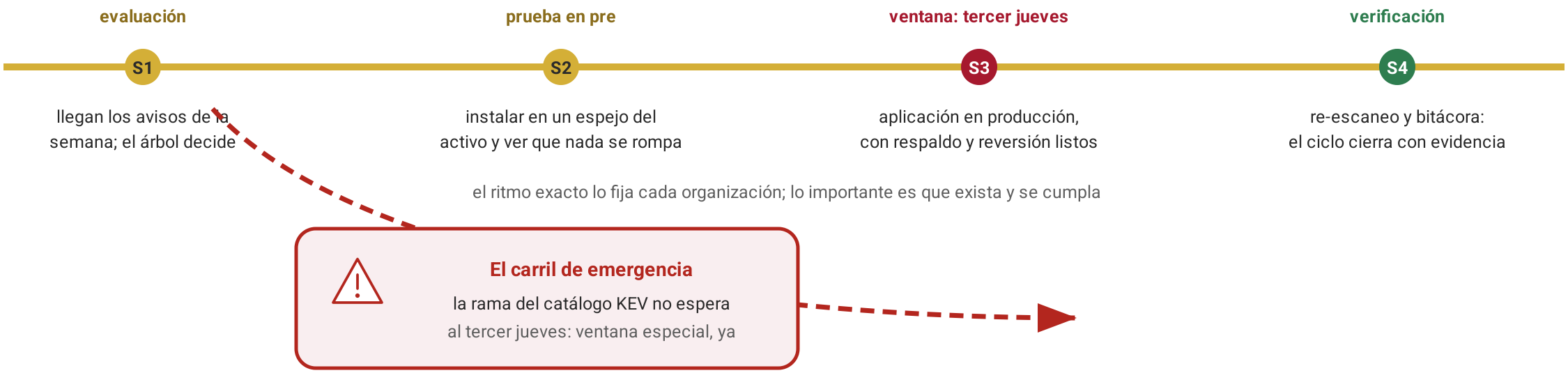
- **Seguridad** — prioriza, verifica y reporta el cierre
- **Operaciones** — ejecuta la ventana y el plan de reversión
- **Dueño del activo** — aprueba el cambio y responde por el servicio

El parche es un cambio, no un acto de fe: cada paso deja evidencia.

La misma guía lo repite: sin ventana, respaldo y reversión, el remedio puede doler más que la enfermedad.

El calendario del parche: rutina y emergencia

Una ventana mensual para la rutina; un carril aparte, más rápido, para lo que no espera.



DENTRO DE CADA VENTANA, EL ORDEN TAMBIÉN IMPORTA

1 · lo expuesto a Internet

la cara pública de la DMZ y del perímetro

2 · los críticos internos

base de datos, directorio, respaldos

3 · el resto, por severidad

estaciones, impresoras, equipos de prueba

NIST SP 800-40 Rev.4 (2022) · ISO/IEC 27002:2022, control 8.32: gestión de cambios

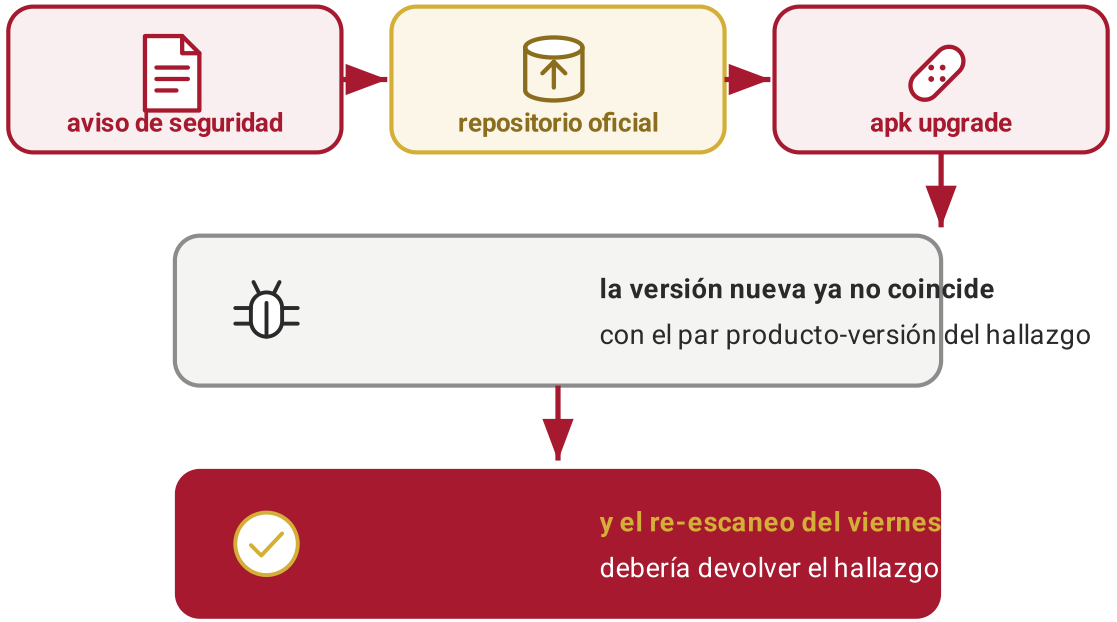
Parchear el laboratorio: apk, apt y dnf

Los comandos reales de las tres familias; la diferencia entre actualizar y reiniciar.

```
# Alpine, la del laboratorio (Lab 1)
apk update        # refrescar el índice
apk upgrade       # subir paquetes parcheados
apk info -v openssh  # versión instalada

# las otras dos familias, de referencia
apt update && apt upgrade   # Debian/Ubuntu
dnf upgrade                 # Fedora/RHEL
```

Regla del laboratorio: parchear es `apk upgrade` + reiniciar el servicio (`rc-service sshd restart`); solo el kernel pide reiniciar la máquina.



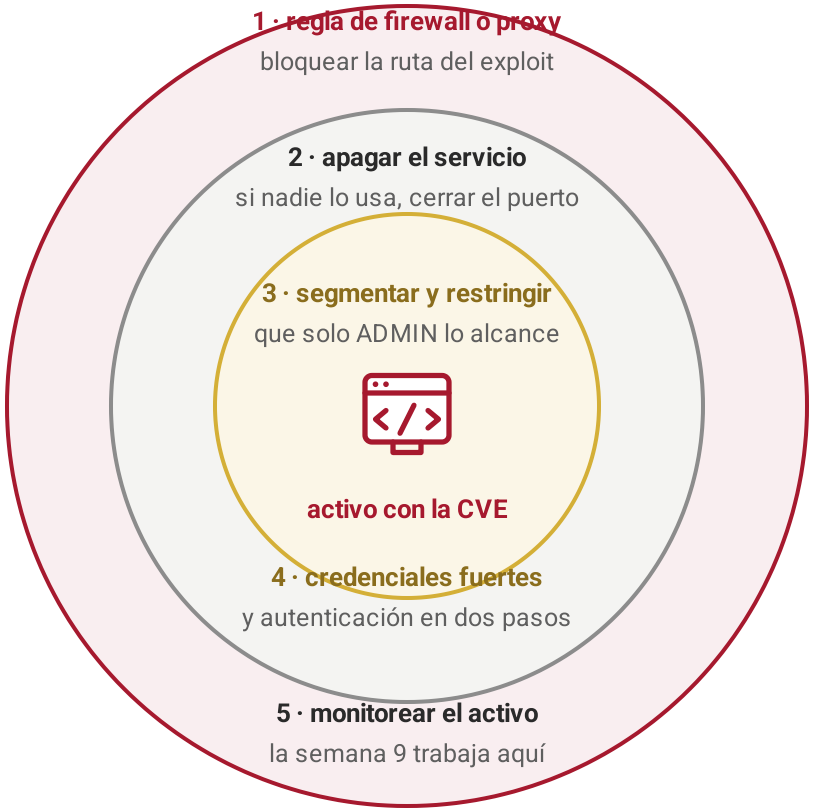
Dos precisiones que evitan sustos

· parchear no es reiniciar todo: cada servicio se reinicia solo, cuando lo necesita
· «upgrade» trae lo parcheado; las funciones nuevas pueden esperar su ventana

apk(8), Alpine Linux (wiki.alpinelinux.org) · apt(8)/dnf(8) manuales de las distribuciones

Cuando no hay parche: mitigaciones compensatorias

El hueco se tapa por fuera mientras la versión corregida llega, o no llega nunca.



Las tres situaciones típicas

· el parche aún no existe, o el producto ya no tiene soporte

· el parche rompe una función del negocio y la ventana se aleja

· el activo es delicado y el cambio exige planearlo con calma

El «parche virtual»

la regla del perímetro que bloquea la ruta del exploit;

la industria lo llama así porque protege sin tocar el activo:

en el laboratorio es una regla del OPNsense, no un hechizo

La regla de oro de la mitigación

· se elige una y se escribe por qué esa y no otra,

· se prueba que realmente bloquee la ruta del exploit,

· y se le pone fecha: mitigación sin fin de obra es deuda

aceptada por descuido, no por decisión

EXCEPCIÓN

El riesgo aceptado se documenta, no se olvida

La excepción es un documento con vencimiento, no un chat de mensajería.

REGISTRO DE EXCEPCIÓN (FORMATO DEL CURSO)

Hallazgo: CVE-AAAA-NNNNN, severidad y señales

Activo: 10.10.20.10 · servidor web de la DMZ

Justificación: el parche rompe la pasarela de pagos

Mitigación: regla del perímetro que bloquea la ruta

Fecha límite: 60 días, o la próxima versión del proveedor

Responsable: dueño del activo, con nombre y correo

Aprobación: comité de cambios, acta del día de la sesión

campos de ejemplo; el formato se adapta a cada organización



Lo que cambia una excepción bien manejada

· el riesgo aceptado es visible: aparece en el tablero de la semana 1

· la mitigación se prueba, no se supone

· y la renovación exige una razón nueva: el silencio no renueva nada

Riesgo aceptado no es riesgo ignorado

Es una decisión de negocio con respaldo técnico, fecha de vencimiento y un nombre que la firma: eso la separa del descuido.

ISO/IEC 27001:2022: tratamiento y aceptación del riesgo · NIST SP 800-40 Rev.4 (2022)

Hardening: cerrar todo lo que no se usa

La misma idea de la semana cinco, ahora sobre los hosts del ciclo: menos superficie, menos deuda.

Semana 5 · el perímetro

planos de gestión, acceso administrativo por SSH y listas de control en los dispositivos de red

Semana 10 · los hosts del ciclo

el sistema operativo y sus servicios: cada servicio cerrado es un hallazgo que el escáner ya no reportará

Qué se cierra en un host

· servicios instalados «por si acaso» que nadie usa

· cuentas heredadas, sin dueño y con contraseñas viejas

· configuración por defecto: puertos, banners, rutas

· protocolos heredados sin cifrado ni autenticación

La ganancia, medida por el escáner

· un servicio desinstalado no genera hallazgos, ni hoy ni en el próximo escaneo: es la única remediación permanente

· y simplifica el inventario: menos paquetes, menos CPE que vigilar en cada aviso de seguridad

El parche cura una vulnerabilidad; el hardening elimina la posibilidad de que exista.

Por eso el ciclo de esta semana termina en configuración, no en ventana de mantenimiento.

Diagrama propio · espiral del curso: S05 (perímetro) → S10 (hosts) · CIS Controls v8.1 (2024)

La línea base escrita: los perfiles de CIS

Bancos de recomendaciones por sistema, en dos niveles; se citan, no se copian.

Perfil Nivel 1

prácticas básicas y prudentes,
de bajo impacto en la operación:
parches al día, servicios mínimos,
bitácoras activas, permisos revisados

punto de partida real de cualquier organización

Perfil Nivel 2

defensa en profundidad para
sistemas de alto valor:
restricciones severas, aislamiento
de la gestión, cifrado exigido

aplica donde el riesgo del activo lo justifica

Cómo se usan en el curso

· cada recomendación citada con su número,
como en las fuentes de la semana

· la licencia permite citar, no reproducir:
nada de copiar el texto completo

· la guía de Alpine del lab las traduce a apk

Una recomendación, tal como se cita en este curso (paráfrasis con número)

«Asegurar que los permisos de los archivos de tareas programadas permitan solo al dueño escribir»

— la idea en mis palabras, el número del banco como referencia para consultar la letra original.
Cada banco existe para un sistema concreto: distribuciones de Linux, gestores de bases de datos, navegadores, nubes.

Perfil 1 primero, completo; el 2 por activo, cuando su riesgo lo pida. Nadie endurece lo que no mide.

CIS Benchmarks (cisecurity.org/benchmarks), citar recomendaciones · licencia CC BY-NC-ND: no reproducir el texto

LABORATORIO

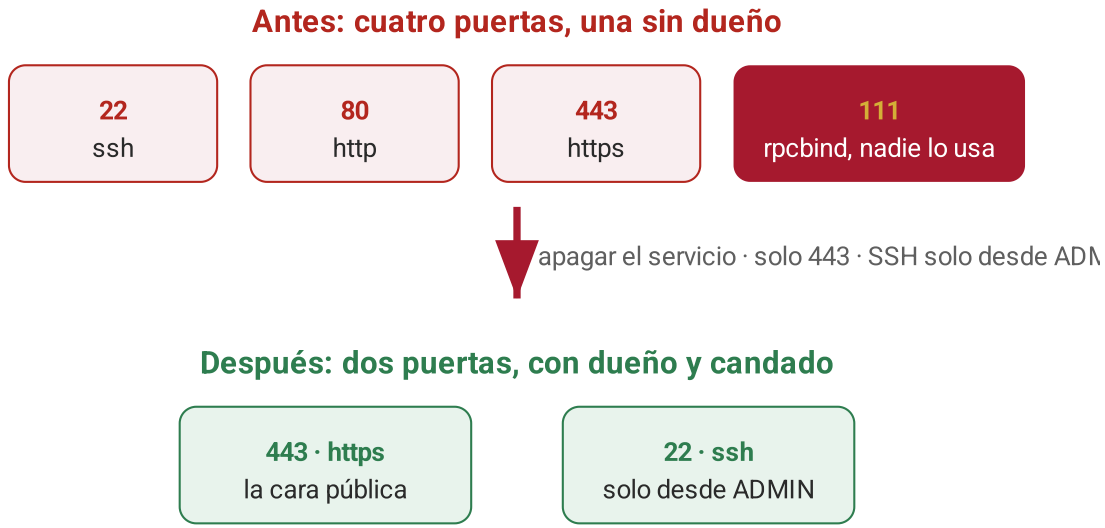
Endurecer la DMZ: menos puertos, menos deuda

La misma Alpine de siempre; el escaneo mide el antes y el después.

```
# antes: qué responde el servidor de la DMZ
nmap -sV 10.10.20.10
22/tcp  open  ssh     OpenSSH 9.7
80/tcp  open  http    nginx
443/tcp open  https   nginx
111/tcp open  rpcbind ← nadie lo usa

# cerrar el servicio huésped
rc-update del rpcbind default
rc-service rpcbind stop
apk del rpcbind
```

Después, dos reglas más: el sitio web solo por 443, y el SSH de la DMZ alcanzable únicamente desde la red ADMIN — eso se hace en el OPNsense, no en el host.



La verificación no es un discurso, es un comando

· en el host: rc-status y el puerto local con ss -tln

· desde la LAN: nmap de nuevo; el 111 ya no responde

· y el re-escaneo del viernes lo certifica para el reporte

Diagrama propio · práctica sobre el Lab 1: apk(8), rc-service(8), OpenRC (wiki.alpinelinux.org) · salida de ejemplo

La línea base se automatiza o se desvía sola

Definir, aplicar y auditar configuración; la desviación se detecta, no se descubre por accidente.

1 · Definir
el perfil del banco, adaptado al rol de cada activo

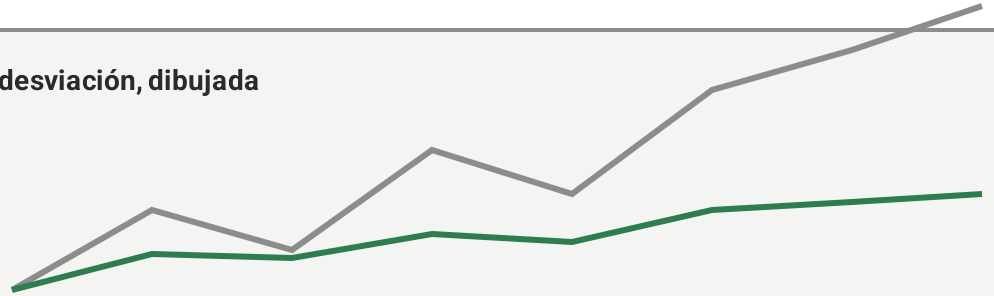
2 · Aplicar
el mismo cambio en cien hosts, escrito una sola vez

3 · Auditar
evaluaciones periódicas de cumplimiento por activo

4 · Corregir
toda desviación abre un trabajo con responsable

el ciclo de configuración también gira: cada vuelta re-audita

La desviación, dibujada



línea base (verde) contra la deriva real (gris): la brecha es la desviación
sin auditoría nadie la ve… hasta que aparece en un incidente

Tres formas de hacerlo, como ejemplo de industria

· evaluaciones de cumplimiento con estándar abierto (SCAP)

· agentes de seguridad con evaluación de configuración

· despliegue declarativo del estado completo del host

en el laboratorio: la lista de verificación del viernes + nmap como auditor externo

OpenSCAP (open-scap.org) · Wazuh SCA (wazuh.com) · Ansible (ansible.com), citados como ejemplos de industria

VERIFICAR

El ciclo solo cierra con evidencia del re-escaneo

Remediar y confiar no es verificar; el segundo reporte es la firma del trabajo.

1 · hallazgo verificado
con sus tres señales y el contexto del activo

2 · decisión del árbol
parche, mitigación o excepción documentada

3 · remediación ejecutada
en ventana, con respaldo, reversión y bitácora

4 · re-escaneo del mismo alcance
misma tarea, mismos hosts, para que la comparación valga

Reporte antes (extracto de ejemplo)

`10.10.20.10 · 443/tcp · severidad 8,6 · abierta`

la evidencia que nadie quiere volver a ver

Reporte después (extracto de ejemplo)

`10.10.20.10 · 443/tcp · hallazgo cerrado`

la misma línea, resuelta: eso es evidencia defendible

El paquete de evidencia del cierre

reporte antes, reporte después, bitácora del cambio y responsable: cuatro archivos que responden cualquier pregunta futura, incluida la del auditor que llegue en seis meses preguntando por qué aquello estuvo abierto tres semanas.

NIST SP 800-40 Rev.4 (2022): verificación · Greenbone docs: comparación de reportes (docs.greenbone.net)

SÍNTESIS

Lo que queda de la Parte 3

Del reporte a la decisión, del parche a la configuración, y siempre con evidencia.

1 · El árbol antes que la lista

catálogo, exposición, automatización e impacto:
cuatro preguntas y una ruta con reloj.

el activo pone el contexto que el número no trae

2 · El parche es un cambio

ventana, respaldo, reversión y verificación:
apk upgrade con método, no con fe.

la rutina mensual y el carril de emergencia

3 · Sin parche, mitigación con fecha

parche virtual, servicio cerrado, segmentación,
credenciales fuertes, monitoreo.

y la excepción, siempre documentada y con vencimiento

4 · Hardening: la remediación permanente

línea base de banco, automatizada, auditada;
menos superficie, menos deuda.

lo que no existe no se parchea ni se prioriza

Toca el turno del mundo real: caso colombiano y práctica guiada.

En la Parte 4 todo este método se corre sobre el laboratorio: siete pasos, con reporte antes y después.

Diagrama propio · síntesis de la Parte 3

PARTE 4 DE 4

4

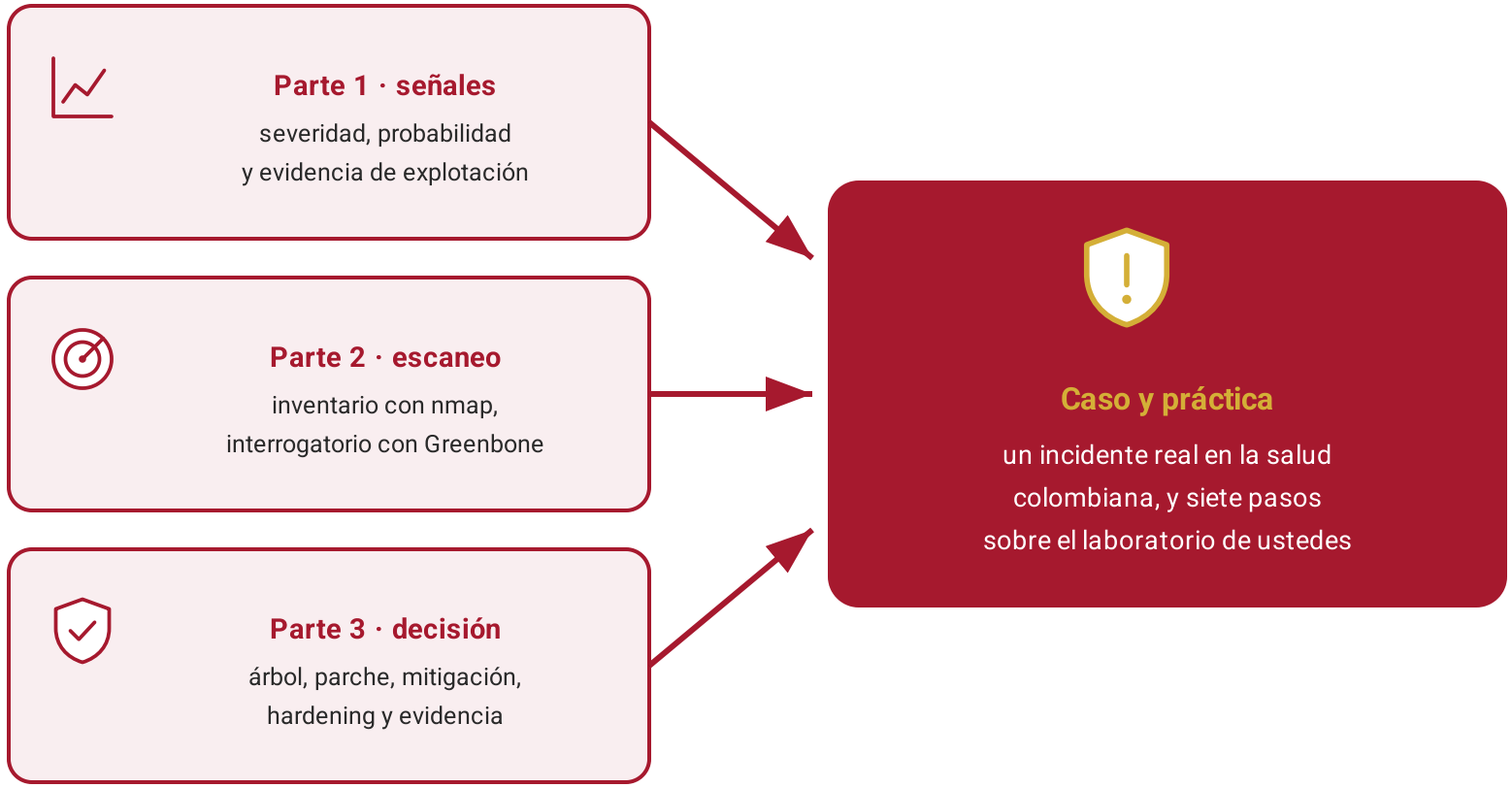
Caso colombiano y práctica de escaneo

Semana 10 · Hardening y gestión de vulnerabilidades: parcheo, CVEs, escaneo de vulnerabilidades

Caso Keralty | Lab 1: nmap + Greenbone | Priorizar con CVSS + EPSS + KEV | Qué sigue

Todo el método en la mesa: hoy, el caso y la práctica

Las señales, el escaneo y la decisión se prueban contra un incidente real y contra el laboratorio.



Los siete pasos de hoy

1 · inventario: quién responde

2 · puertos y servicios de la DMZ

3 · objetivo y credenciales en el escáner

4 · escaneo y reporte de hallazgos

5 · priorizar con las tres señales

6 · remediar en el laboratorio

7 · verificar con re-escaneo

Formativa, de demostración:

los pasos se muestran en vivo y se repiten en casa con la misma guía, sobre la red del laboratorio

Diagrama propio · síntesis de la semana · práctica formativa sobre el Lab 1

CASO CO

Keralty, finales de 2022: salud bajo extorsión

Un grupo de salud colombiano golpeado por ransomware y presionado con la publicación de datos.

nov 2022 — 1 — ransomware golpea al grupo de salud de EPS Sanitas; caen canales de servicio

20 dic 2022 — 2 — los atacantes publican datos sensibles para presionar el pago del rescate

21 dic 2022 — 3 — la empresa responde: los datos de usuarios no se comprometieron; revela el volumen robado

feb–mar 2023 — 4 — RansomHouse amenaza con vender más; el golpe alcanzó a Cruz Verde y a divisiones en el exterior



Lo que este caso le dice a la gestión de vulnerabilidades

· Un incidente en un proveedor crítico de salud se mide en pacientes sin cita, no solo en servidores caídos.

· La extorsión con datos robados agregó un segundo daño al primero: la publicación escaló el incidente semanas.

· La causa técnica exacta no se hizo pública; por eso aquí se cita la cronología verificable y no la especulación.

· La lección operativa: sin inventario, escaneo y priorización, «no sabemos qué estaba expuesto» es la única respuesta.



De la salud a cualquier sector: cada servicio expuesto es una promesa de negocio con un costo de seguridad.

El resto de la práctica de hoy es exactamente la disciplina que este caso echa de menos: mirar la red como la mira un atacante.

Prensa: Blu Radio, Portafolio, El Colombiano, Semana, Caracol, Infobae (dic-2022 a mar-2023) · inicio: nov-2022

CONTRASTE

El mismo caso, con el ciclo funcionando

Ejercicio de aula: la cronología real frente a una semana hipotética del ciclo de esta semana.

Lo que pasó (cronología verificada)

servicios caídos en plena operación

datos publicados para presionar el pago

semanas de atención afectada y de

nueva información filtrándose en 2023

el incidente marcó el cierre del año para el sector

si el ciclo hubiera corrido

Una semana hipotética del ciclo (aula)

lunes: escaneo programado detecta un servicio expuesto

martes: el hallazgo está en el catálogo federal: se salta la fila, ventana de emergencia y triaje forense

miércoles: parche aplicado con respaldo y reversión

jueves: re-escaneo limpio y evidencia archivada

Días, no semanas

el hallazgo expuesto se remedia en la misma semana

Menos superficie

lo que no está publicado no entra por ahí

Respuesta con datos

inventario y bitácora sostienen lo que se dice

Ningún programa elimina todo el riesgo; el ciclo es lo que cambia el tamaño del desastre.

El ejercicio es hipotético y así se marca: la cronología de la izquierda es la verificable; la de la derecha, la disciplina que enseña este curso.

Diagrama propio · ejercicio de aula hipotético, basado en la cronología del caso (prensa, 2022–2023)

El marco colombiano y la autorización para escanear

Antes de tocar la red en la práctica: qué dice el país y qué exige el oficio.

CONPES 3995 (2020): la política nacional

confianza y seguridad digital como política de Estado,
con la salud entre la infraestructura crítica del país

ColCERT y los CSIRT sectoriales

el circuito nacional de advertencia y respuesta:
guías, alertas y un adonde reportar incidentes

La organización

traduce el marco en su propio programa:
inventario, escaneo, priorización y evidencia

Las reglas de la práctica de hoy

1 · se escanea únicamente el laboratorio propio de VirtualBox: sus máquinas, su red, su permiso

2 · el alcance va por escrito, como en la parte dos: solo la DMZ, en la ventana acordada

3 · las credenciales de escaneo son dedicadas, de solo lectura y se retiran al terminar

4 · fuera del laboratorio, escanear red ajena sin autorización escrita está fuera del marco y de la ley

la guía de pruebas del NIST (SP 800-115) es el molde

En la vida profesional: la autorización escrita es parte del trabajo, no un trámite.

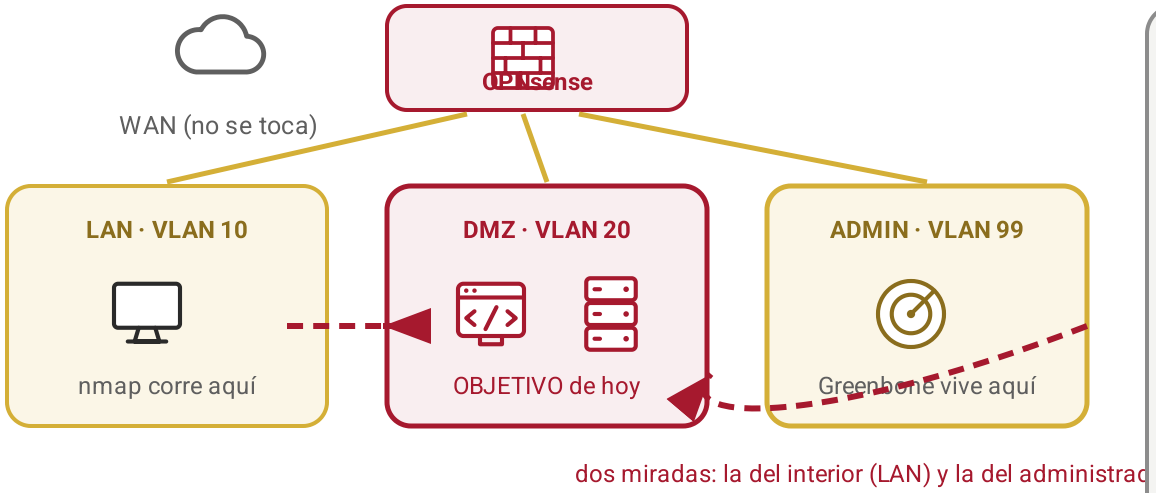
El marco nacional da el contexto; el permiso del dueño del activo habilita cada sonda.

DNP, CONPES 3995 (2020): Política Nacional de Confianza y Seguridad Digital · NIST SP 800-115 (2020)

PRÁCTICA

La práctica: cerrar el ciclo una vez, de punta a punta

Misma red de siempre, ojos nuevos: descubrir, interrogar, priorizar, remediar y verificar.



Siete pasos, una entrega

1 inventario de vivos con nmap -sn

2 puertos y servicios con -sV

3 objetivo y credenciales en Greenbone

4 escaneo completo y lectura del reporte

5 priorizar tres hallazgos con las señales

6 remediar en el laboratorio

7 verificar con re-escaneo y documentar

entrega: el paquete de evidencia de la parte 3, con reporte antes y después

Condiciones de la demostración

Todo corre en el laboratorio de cada quien; los comandos son los reales de la guía y se muestran en vivo, paso a paso, con tiempo para repetirlos: la práctica es formativa y la medida del éxito es el paquete de evidencia, no la velocidad.

Diagrama propio · plataforma del curso: VirtualBox + OPNsense + Alpine (Lab 1) · práctica formativa

PASO 1

Inventario: quién responde en la DMZ

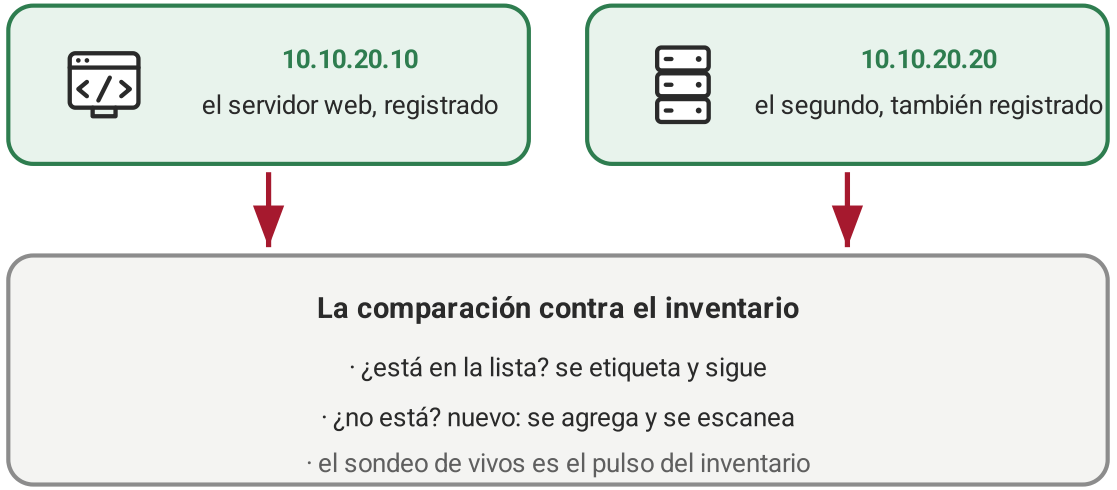
Primer comando de la práctica: la lista de vivos, antes de tocar un solo puerto.

```
# Alpine de la LAN, como root (Lab 1)
apk add nmap
nmap -sn 10.10.20.0/24

Nmap scan report for 10.10.20.10
Host is up (0.0012s latency).
Nmap scan report for 10.10.20.20
Host is up (0.0009s latency).
Nmap done: 256 addresses (2 hosts up)
scanned in 1.81 seconds

# si el firewall bloquea el eco: -Pn
nmap -Pn -sn 10.10.20.10
```

Contra el inventario: ¿los dos vivos están registrados? Un equipo nuevo o desconocido se investiga hoy, no el viernes.



Dos hosts arriba, 254 en silencio:
un resultado corto no es mala suerte: es la red bien segmentada

Ojo con -Pn:
asume el host vivo y pasa a puertos: útil, pero ya no es «descubrimiento»

PASO 2

Puertos y servicios: la cara pública de la DMZ

Con versión, la tabla se puede comparar contra el plan y contra el catálogo.

```
# paso 2: interrogar los dos vivos
nmap -sV 10.10.20.10 10.10.20.20

PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.7
80/tcp   open  http    nginx 1.27.0
443/tcp  open  https   nginx 1.27.0
111/tcp  open  rpcbind 2.0
5000/tcp filtered upnp
```

La pregunta de control: ¿qué de esta lista estaba en el plan? Todo lo que no estaba es superficie no autorizada, y hoy lo tenemos en evidencia.

Cómo se lee la tabla

puerto
dónde responde

estado
abierto o filtrado

servicio
suposición

versión
el dato que abre el catálogo

Contra el plan del laboratorio

· 22 solo para ADMIN: ¿por qué lo ve la LAN? regla del firewall

· 80 abierto con 443 disponible: la puerta que sobra

· 111 sin dueño: el hallazgo de superficie de la parte 3

el estado «filtered» también informa:
dice dónde el firewall está trabajando, y se anota igual

captura de pantalla de esta tabla:
es la página uno del paquete de evidencia

PASO 3

Preparar el escáner: objetivo y credenciales

Dos pantallas antes de escanear: a quién interrogar y con qué llave entrar.

Pantalla 1 · Configuración → objetivos

nuevo objetivo: «DMZ del laboratorio»,
rango 10.10.20.0/24, sin exclusiones

Pantalla 2 · Configuración → credenciales

nueva credencial SSH para la Alpine:
usuario dedicado de solo lectura, su clave

Antes del primer escaneo, una sola vez:

· sincronizar el feed comunitario de pruebas
· revisar que la interfaz web responda cifrada
· y anotar el usuario de escaneo en la bitácora del curso

El mapa de la pantalla



Por qué credencial dedicada y de solo lectura

· el escáner guarda la llave: que no sea la del administrador
· solo lectura, y al terminar la práctica, se retira
· así el reporte no depende de una persona ni queda una llave olvidada en el escáner

Sin credenciales también se puede escanear:

el escaneo externo es la vista del atacante y va primero;
el autenticado es el que precisa, y es el que corrige
la práctica corre los dos, en ese orden

Greenbone Community Edition: GSA, credenciales y objetivos (docs.greenbone.net), consultado oct-2026

PASO 4

Ejecutar el escaneo y leer el reporte

Del botón a la lista: tarea nueva, perfil completo, y la lectura por host.

En la pantalla de tareas, paso a paso

1. tarea nueva: «Escaneo DMZ — semana 10»
2. objetivo: DMZ del laboratorio (del paso 3)
3. perfil: completo y rápido, con la credencial
4. iniciar; el estado pasa de solicitado a corriendo
5. al terminar: «terminado» y se abre el reporte

la primera vez tarda: el feed procesa cientos de pruebas por host

Qué mirar primero

· severidad alta: la lista corta que se lee con las cinco preguntas

· hosts sin hallazgos: también es información, y se agradece

EL REPORTE RESUMIDO (CIFRAS ILUSTRATIVAS)

host	hallazgos por severidad
10.10.20.10 servidor web	1 · 2 · 3 — alta · media · baja
10.10.20.20 segundo servidor	0 · 1 · 2

La lectura correcta

un solo hallazgo alto concentra la atención del viernes:

el .10 es el activo a trabajar, y el resto sigue su camino

(números de ejemplo; el método no depende de los números)

El reporte no es la entrega;

la entrega es la decisión del paso siguiente, con su evidencia

PASO 5

Priorizar: tres hallazgos, tres señales, tres rutas

La hoja de trabajo del paso cinco, con datos de ejemplo; el método es lo evaluable.

hallazgo (ejemplo)	CVSS	EPSS	en KEV	exposición	decisión
A · versión del servidor web afectada por una CVE conocida del mismo producto	**9,8** crítica	**0,95** percentil alto	**sí** explotada hoy	Internet, 443/tcp la cara pública	**HOY + triaje forense** todo el árbol aprieta a la vez
B · biblioteca del canal seguro con vulnerabilidad anunciada	**7,4** alta	**0,04** percentil bajo	**no** sin evidencia	Internet, 443/tcp el mismo host	**ventana corta** días; la exposición pesa más
C · agente de respaldo local con versión antigua en el segundo servidor, sin salida	**5,3** media	**0,01** mínima	**no** —	red interna sin publicación	**deuda programada** ventana regular, registrada

Cómo se llenó esta hoja

columnas de señales del hallazgo (partes 1 y 2), luego el contexto del activo, y al final la decisión con plazo: el catálogo manda, la probabilidad desempata, la severidad ordena el resto.

Tarea del paso 5 en casa:

la misma hoja con los hallazgos reales del reporte de su propio laboratorio

Diagrama propio · método: FIRST (CVSS v4.0, EPSS) + CISA KEV · hallazgos de ejemplo: ilustrativos

PASO 6

Remediar: cada hallazgo con su acción y su comando

El parche del paquete, la regla del firewall y la deuda registrada: el plan de la hoja anterior.

```
# hallazgo A: parchear y reiniciar el servicio
apk update && apk upgrade
rc-service nginx restart

# superficie (parte 3): cerrar el huésped
rc-update del rpcbind default
rc-service rpcbind stop
apk del rpcbind

# comprobar en el propio host
ss -tln   # qué puertos quedan abiertos
```

Antes de cada comando: respaldo del estado (`apk info` previo) y ventana acordada; el plan de reversión es parte del cambio, no un extra.

A · hoy, en el propio host

parche del paquete afectado y reinicio del servicio:

aplicar, comprobar el servicio y anotar la versión nueva

B · ventana corta, con mitigación mientras

el parche entra en la ventana acordada; mientras tanto,

regla del OPNsense que restrinja la ruta del exploit

C · deuda programada

se registra en la lista con fecha límite

y se agenda en la ventana regular del ciclo

y cada acción con su bitácora: el paquete de evidencia se arma aquí

apk(8), rc-service(8) · OpenRC (wiki.alpinelinux.org) · NIST SP 800-40 Rev.4 (2022) · comandos del Lab 1

PASO 7

Verificar y documentar: el ciclo, cerrado con evidencia

La misma tarea otra vez; el reporte de después es la firma del trabajo de la semana.

misma tarea, otra vez

1

re-escaneo con el mismo alcance y el mismo perfil

reporte de después

2

el hallazgo A aparece cerrado, y el huésped, fuera

capturas y bitácora

3

antes y después, comando por comando, con su fecha

paquete archivado

4

la evidencia responde por ustedes dentro de un año

Antes (extracto de ejemplo)

10.10.20.10 · severidad 9,8 · abierta

111/tcp · rpcbind · superficie sin dueño

captura del reporte del paso 4

Después (extracto de ejemplo)

10.10.20.10 · hallazgo A · cerrado

111/tcp · ya no responde (verificado con nmap)

la misma sonda, el mismo resultado: limpio

El lunes que viene, todo otra vez: el ciclo no se despide, se programa.

Los siete pasos que acaban de correr son el mismo ritual que sostendrá la red de su empresa toda la vida: la constancia es el control.

FUENTES

Referencias y lecturas de la semana

Normas y estándares primero; los manuales de las herramientas, abiertos durante el laboratorio.

- FIRST. (2023). *Common Vulnerability Scoring System version 4.0: Specification* (first.org/cvss/v4.0).
- FIRST. (2026). *Exploit Prediction Scoring System* (epss.first.org). Consultado el 4 de octubre de 2026.
- CISA. (2026). *Known Exploited Vulnerabilities Catalog*: 1 734 entradas, consultado el 4 de octubre de 2026 (cisa.gov).
- CISA. (2026, 10 de junio). *BOD 26-04: Prioritizing Security Updates Based on Risk*.
- NIST. (2022). *Creating a Patch and Vulnerability Management Program* (SP 800-40 Rev. 4).
- NIST. (2020). *Technical Guide to Information Security Testing and Assessment* (SP 800-115).
- NIST. (2026). *National Vulnerability Database*: 401 104 CVE acumuladas, consultado el 4 de octubre de 2026.
- Lyon, G. (2026). *nmap Reference Guide: Host Discovery; Port Scanning Techniques; NSE* (nmap.org).
- Greenbone. (2026). *Greenbone Community Edition: GSA, tareas y reportes* (docs.greenbone.net).
- Alpine Linux. (2026). *OpenRC, apk y gestión de servicios* (wiki.alpinelinux.org).
- CIS. (2024). *CIS Controls v8.1*, Controles 1 y 7; *CIS Benchmarks* (cisecurity.org).
- ISO/IEC. (2022). *27002:2022*, controles 8.8 (vulnerabilidades técnicas) y 8.32 (gestión de cambios).
- Departamento Nacional de Planeación. (2020). *CONPES 3995: Política Nacional de Confianza y Seguridad Digital*.
- Blu Radio, Portafolio, El Colombiano, Semana, Caracol e Infobae. (dic. 2022 – mar. 2023). Cobertura del incidente del grupo Keralty.

Para el laboratorio: el manual de nmap y la documentación de Greenbone son la consulta permanente de los siete pasos; abran una pestaña con cada uno antes de empezar.

QUÉ SIGUE

La Unidad 2 completa: toca repasarla junta

La semana 11 reúne cifrado, identidad, monitoreo y vulnerabilidades antes del parcial.

Lo que se llevan de la semana 10

Señales
severidad, probabilidad a 30 días y evidencia de explotación

Escaneo
inventario con nmap, interrogatorio con Greenbone

Remediación
árbol, parche con método, mitigación y hardening

Ciclo cerrado
siete pasos corridos, con evidencia antes y después

Semana 10
hoy: gestionar vulnerabilidades

qué está expuesto

→

Semana 11
repaso de la Unidad 2

todo junto, 19–25 oct

Semanas 7 a 10
cifrado · identidad
monitoreo · vulnerabilidades

el mapa para el repaso

La Unidad 2 queda así, en una línea

· cifrar lo que viaja y lo que se guarda (S07) · saber quién entra (S08)

· ver lo que pasa y demostrarlo (S09) · saber qué está abierto y cerrarlo (S10)

· el repaso conecta las cuatro piezas con ejercicios sobre el mismo laboratorio

No desarmen el laboratorio: el repaso de la semana que viene corre sobre la misma red, con las cuatro capas montadas.

Diagrama propio · calendario oficial del curso · contenidos: docs/analisis-tematico.md §2.4